國立高雄大學　Term Project I

資安文件搜尋引擎

選項、取捨與實測結果

主講約 18 分鐘　另有 5 分鐘 Demo

從自主滲透 Agent 到資安文件搜尋

可選做法	自主滲透 Agent／以 Kali 指令為主題／搜尋工具與操作文件
選擇與理由	做資安文件搜尋。課堂要實作爬取、索引和排序，文件有可查證的來源。
實測與變化	先以 Kali、Nmap、Metasploit 驗證查詢與文件是否對得上。
正式範圍	**資安技術文件搜尋**

各站配額和可續跑的爬蟲

可選做法	各站輪流抓／限制每站頁數／分次爬取後續跑
選擇與理由	同時採用輪流、配額和進度存檔，讓大站不會擠滿資料，也能遵守同站限速。
實測與變化	後續擴站仍可維持在作業頁數上限內。v7 固定語料共七站 980 頁。
正式採用	**範圍白名單、限速、可續跑**

標題加權與 BM25 的第一次比較

可選做法	純 TF-IDF／固定加分／BM25／BM25 加比例式標題權重
選擇與理由	固定加分壓過正文分數，改測 BM25 的詞頻飽和與長度調整。標題訊號改按比例加權。
實測與變化	固定加分使早期平均 P@5 從 0.96 降至 0.80。BM25 把 sqlmap 從前五外推到第 1。
撤回／保留	**撤回固定加分，保留 BM25 與比例加權供比較**

同義詞擴展有幫助，也會把答案擠下去

可選做法	只查原詞／加入低權重的資安詞彙和中文關鍵字
選擇與理由	原詞保留 1.0，擴展詞給 0.5，讓「wifi 密碼」能找到寫 WPA key 的文件。
實測與變化	aircrack-ng 進前二，但 sqlmap 由第 1 掉到第 4。
保留比較	**同義詞做成可選開關**

決策 05　v5

重訂相關性規則，固定課程預設

可選做法	關鍵字快判／讀全文、共用標註；BM25 預設／純 TF-IDF 預設
選擇與理由	課程要求以 TF-IDF cosine 為基準。按資訊需求判相關，同一題與文件只判一次。
實測與變化	按較嚴格的標準，純 TF-IDF 測得 0.42。早期的 0.96 使用另一套判法。
正式採用	**純 TF-IDF 預設，全文判定用於比較**

清樣板、還原詞形與長度正規化

可選做法	原版／只清樣板／只還原詞形／兩者一起；另試 pivot
選擇與理由	先解正文雜訊和 scan／scanning，再另測文件長度對分數的影響。
實測與變化	同批標註的純 cosine 依序為 0.42、0.48、0.48、0.54。兩者加 pivot 為 0.68。
採用＋比較	**清樣板與輕量詞形處理進基準，pivot 保留選項**

擴到七站，另外測查詢容錯

可選做法	維持三站／擴到七站；原詞查詢／低權重校正錯字
選擇與理由	補入封包、HTTPS 代理、App 分析與提權資料。英文用編輯距離，中文比拼音。
實測與變化	語料增至 980 頁。容錯可處理 injetcion，另用例子展示成效。
採用＋選用	**七站形成課程語料，錯字容忍保留開關**

調整文件長度和命中詞優先會互相抵銷

可選做法	純 cosine／命中詞優先／pivot／兩種一起，另比導覽頁是否回傳
選擇與理由	保留選項分開跑。同一個查詢詞全出現，也可能是在談別的技術。
實測與變化	pivot 0.84。再加命中詞優先是 0.80。Wi-Fi 題被一篇 SIP 密碼文件往前擠。
保留比較	**導覽總表排除於結果，pivot 與命中詞各自可切換**

逐跳驗證爬取範圍和限速

可選做法	只檢查起始網址／每次請求檢查站點、路徑、robots 與配額
選擇與理由	轉址後可能到不同站或路徑。請求前逐跳核對，才能讓允許範圍與實際請求一致。
實測與變化	v8.1 另做七站重爬，980 頁、1,027 次請求。10 筆 robots 拒絕未發內容請求。
正式採用	**每次請求共用規則，舊快照另外保存**

讓片語與分數都有可核對的依據

可選做法	逐篇掃正文找片語／存每個詞的出現位置；排序與解釋各算／共用公式
選擇與理由	用位置判定詞是否相鄰，並把重複查詢詞和逐詞貢獻納入同一套計算。
實測與變化	代表片語查詢約 49.0 到 4.4 ms。一般查詢約 0.36 到 3.03 ms，索引增至 47.9 MB。
正式採用	**位置索引與逐詞解釋，欄位與詞距加權保留選項**

壓縮索引，保留排序結果

可選做法	完整 JSON 座標／壓縮位置；先解完位置／需要解釋時才解
選擇與理由	採壓縮和按需解碼。提早解碼曾使冷查詢慢，改在顯示結果時才處理完整座標。
實測與變化	47.9 MB 降至 9.8 MB，414 次比較的結果、分數、摘要與解釋相同。
正式採用	**以壓縮後的索引作為網站預設**

同一批題與判定，公平比較九種設定

可選做法	等待雙人標註／另做可追溯的 LM 判定；在開發題選設定／用保留題驗證
選擇與理由	先凍結題目與規則，合併九種設定的候選，全文判定、留引文與複核紀錄。
實測與變化	46 題共 654 組配對。24 道保留題上，TF-IDF 0.400，BM25 0.625。
採用於評估	**BM25 是對照方法，LM 標註明示來源**

站名和不同術語需要不同訊號

可選做法	普通文字 BM25／辨識網址網域／補一般 module／補明確 API 術語
選擇與理由	指定 GTFOBins 時按網域排序。Frida 文件用 enumerateModules，精確術語比一般 module 更貼合。
實測與變化	兩道已知題 P@5 由 0 升至 0.80 與 0.40。16 道新題由 0.350 升至 0.425。
保留實驗	**明確來源與詞彙訊號分開開啟**

功能、權限和效果必須出現在同一個例子

可選做法	同站文字排序／只認功能／配對權限／再排除明示不符的效果
選擇與理由	同頁的 sudo 和反向 shell 可能屬於兩段。文件分類也可能把刪檔列在寫檔下。
實測與變化	16 道新題依序為 0.3375、0.4750、0.5250、0.6000。附加寫入仍為 0。
保留實驗	**以同例的官方證據優先排序**

站內附加先補文件，再看排序

可選做法	原資料／補三頁後沿用舊排序／補三頁後依附加證據重排
選擇與理由	原快照缺有附加證據的條目。先單獨測收錄，再測在同一份 983 頁上重排。
實測與變化	已知題前五由 0 筆變 3 筆。重排後仍 3 筆，第三個答案從第 4 升到第 3。
採用於實驗	**保留 983 頁快照與站內附加排序**

決策 16　v8.6

站外附加補完資料仍排不進前五

可選做法	補資料沿用舊排／只排除指定站／排除後按同例效果與權限排序
選擇與理由	舊排和來源排除都找得到這三篇，位置仍太低。第三種讓可查證的操作排前面。
實測與變化	三篇原本在第 26、347、549 名。只排除站點後為 22、245、447，完整排序後為 1、2、3。
採用於實驗	固定 986 頁，比較同一查詢的兩種排序

決策 17　v8.6

覆寫、附加與刪檔分開判定

可選做法	用「寫檔」分類／核對同一例子的實際效果與權限
選擇與理由	指定輸出位置只表示有寫入。要看有沒有取代舊內容、加到後面或刪除檔案。
實測與變化	覆寫舊題 0.20 到 1.00，站外附加舊題 0 到 0.60。12 道新題平均 0.1833 到 0.6333。
有條件採用	只在實驗模式啟用，課程仍預設純 TF-IDF

決策 18　最後去留

課程基準和延伸實驗各有入口

可選做法	把最高分設定當預設／保留課程基準，讓改進可以切換
選擇與理由	課程要求純 TF-IDF，分數也只在各自題組成立。延伸方式由使用者明確選擇。
實測與變化	980 頁展示原基準。986 頁展示 v8.5 與 v8.6 對照。舊的固定標題加分撤回。
最終採用	**基準預設，延伸選用，失敗結果留在紀錄**

決策 19　展示

把實驗放回正式搜尋介面

可選做法	命令列跑實驗／同頁切換、展開證據並開索引原文
選擇與理由	同一查詢與語料直接切換版本，課程基準可單獨演示。
實測與變化	Chrome 已驗證課程搜尋、版本切換、原文、評估下載與無結果。
本機採用	**先展示 980 頁基準，再切 986 頁對照**

http://127.0.0.1:5057/

三篇站外文件在不同做法下的名次

文件	舊排序	僅排除指定站	來源與效果排序
Debian hosts	26	22	1
Ubuntu vsftpd	347	245	2
Ubuntu Apache2	549	447	3

同一查詢、同一份 986 頁快照，數字為排名。

v8.6 搜尋與同例證據


IR Lab
搜尋
v8.6 實驗
評估
寫入效果實驗
寫入效果搜尋
在相同語料上比較 v8.5 與 v8.6，查看附加、覆寫和刪檔的原文證據。
索引文件
986
outside GTFOBins append to a local file with sudo
搜尋 ↗
模式
寫入效果 · v8.6 語料
版本
v8.6 · 同例效果證據
試試看
追加附加 ↗
sudo 覆寫 ↗
相同語料的排序比較
搜尋結果 10
2.4 ms
切換至 v8.5 對照 ↗
操作 append　權限 sudo　排除 GTFOBins　3 筆有同例證據
查詢詞 outside · gtfobin · append · local · file · sudo
01
https://wiki.debian.org/BootstrapBootableSystem
2.0828
BootstrapBootableSystem - Debian Wiki
▼ 查看同例證據
echo "127.0.1.1 $(cat ${debstrapFolder}/etc/hostname)" | sudo tee -a "${debstrapFolder}/etc/hosts"
... replace Systemd-coupled ones from Debian. Create or edit basic config files /etc/fstab mmdebstrap creates just an empty stub, so you need to list the rootFS and any subvolumes manually, including the ESP at /boot/efi . See fstab for details. /etc/hostname Put a hostname of your choice into this file, for example: echo my-new-laptop | sudo tee "${debstrapFolder}/etc/hostname" /etc/hosts mmdebstrap creates entries necessary for basic networking, so just add an entry for the hostname chosen above: echo "127.0.1.1 $(cat ${debstrapFolder}/etc/hostname)" | sudo ...